POLITÉCNICO COLOMBIANO JAIME ISAZA CADAVID	FACULTAD DE INGENIERIAS DIPLOMADO EN CIBERSEGURIDAD PRACTICA KALI LINUX	Código: FD-GC195 Versión: 01

ASIGNATURA	CÓDIGO: ING: Diplociber	NOMBRE: Implementación Práctica: Snyk, CLI
PROFESOR: Edwin Andrés Ochoa Agudelo		FECHA: 29/10/2026

TIPO DEVALUACIÓN	TALLER	QUIZ	PARCIAL	FINAL	¿OTRO – CUÁL?
	N°5→10%				

FECHA		SEMESTRE	2026_02	
NOMBRE DEL ESTUDIANTE				
DOCUMENTO		GRUPO	01	
DOCENTE	EDWIN OCHOA	ASIGNATURA	DIPLOMADO CIBERSEGURIDAD	

SAST • SCA • CVE/CWE/CVSS • OWASP • Remediación • Shift-Left • CI/CD

1. Presentación de la actividad

Los estudiantes asumirán el rol de auditores de seguridad de aplicaciones (AppSec Engineers). Evaluarán un proyecto de software en un entorno controlado, identificarán vulnerabilidades mediante Snyk, analizarán su riesgo real, documentarán la causa raíz, aplicarán remediaciones funcionales, verificarán la corrección y diseñarán controles para evitar la reincidencia.

La actividad aplica el ciclo: detección → análisis → priorización → remediación → verificación → prevención. La guía original exige seleccionar tres vulnerabilidades y documentar métricas, causa raíz, explotación, remediación y salvaguardas; esta versión amplía esos requisitos.

2. Objetivo general

Realizar una auditoría práctica de seguridad de una aplicación utilizando Snyk CLI y, cuando sea habilitado por el docente, Cursor/MCP, identificando y priorizando vulnerabilidades de código y dependencias, aplicando remediaciones técnicamente justificadas y verificando mediante un nuevo análisis que los hallazgos seleccionados hayan sido corregidos.

3. Competencias

- Ejecutar análisis SCA sobre dependencias directas y transitivas.
- Ejecutar análisis SAST sobre código fuente y relacionar hallazgos con CWE y OWASP.
- Interpretar CVE, CWE, CVSS y severidad sin limitarse a copiar el resultado de la herramienta.
- Analizar causa raíz, vector de ataque e impacto sobre Confidencialidad, Integridad y Disponibilidad.
- Priorizar vulnerabilidades considerando severidad, explotabilidad y reachability cuando exista evidencia.
- Aplicar remediaciones funcionales y comprobar que no introduzcan regresiones.
- Generar evidencia técnica reproducible mediante capturas, terminal, código y comparación antes/después.
- Proponer controles Shift-Left: reglas de IDE, linters, pre-commit y Quality Gates en CI/CD.

ASIGNATURA	CÓDIGO: ING: Diplociber	NOMBRE: Implementación Práctica: Snyk, CLI
PROFESOR: Edwin Andrés Ochoa Agudelo		FECHA: 29/10/2026

TIPO DEVALUACIÓN	TALLER	QUIZ	PARCIAL	FINAL	¿OTRO – CUÁL?
	N°5→10%				

- Comunicar hallazgos técnicos a desarrollo, seguridad y gestión.

4. Alcance y reglas de seguridad

- Trabajar únicamente sobre el laboratorio, repositorio o aplicación autorizada por el docente.
- No escanear ni explotar sistemas, dominios, IP, repositorios o aplicaciones de terceros.
- No publicar API tokens, contraseñas, secretos, cookies ni credenciales.
- Si se utiliza SNYK_TOKEN, manejarlo como secreto y nunca incluirlo en código versionado.
- Las pruebas de explotación se limitarán al laboratorio controlado.
- Toda corrección asistida por IA debe ser revisada por el estudiante antes de aceptarse.

5. Requerimientos previos

- Proyecto de laboratorio Node.js o Python proporcionado por el docente.
- Cuenta autorizada de Snyk.
- Node.js/npm cuando corresponda.
- Snyk CLI instalado.
- Cursor/MCP si el docente lo habilita.
- Git configurado.
- Conocimientos básicos de Git, código, vulnerabilidades web y terminal.

6. Desarrollo de la actividad

Fase 1. Preparación y autenticación

1. Crear/usar la cuenta autorizada de Snyk.
2. Configurar snyk auth o SNYK_TOKEN según el laboratorio.
3. Ejecutar snyk whoami y guardar evidencia ocultando datos sensibles.
4. Verificar el proyecto local.
5. Registrar sistema operativo, versión de Snyk CLI, lenguaje y proyecto.

Fase 2. Análisis SCA

Ejecutar y documentar:

- snyk test
- snyk test --severity-threshold=high
- snyk monitor (si el docente lo solicita).

Para cada dependencia vulnerable registrar paquete, versión, dependencia directa/transitiva, CVE/CWE si aparece, severidad, CVSS, versión segura recomendada e impacto.

ASIGNATURA	CÓDIGO: ING: Diplociber	NOMBRE: Implementación Práctica: Snyk, CLI
PROFESOR: Edwin Andrés Ochoa Agudelo		FECHA: 29/10/2026

TIPO DEVALUACIÓN	TALLER	QUIZ	PARCIAL	FINAL	¿OTRO – CUÁL?
	N°5→10%				

Fase 3. Análisis SAST

Ejecutar:

snyk code test

Analizar código propio. Cuando exista, incluir un hallazgo relacionado con inyección SQL, XSS, autenticación/autorización, manejo inseguro de datos u otra debilidad de aplicación.

Fase 4. Selección obligatoria de vulnerabilidades

- Vulnerabilidad 1 — SAST: debilidad localizada en código propio.
- Vulnerabilidad 2 — SCA: dependencia vulnerable, preferiblemente con CVE y versión segura.
- Vulnerabilidad 3 — SAST o SCA: hallazgo adicional que permita demostrar análisis de riesgo, remediación y prevención.
- Al menos una debe relacionarse con OWASP Top 10 cuando la naturaleza del hallazgo lo permita.
- Si el laboratorio no produce un tipo concreto, justificar la selección alternativa con evidencia de Snyk.

7. Requerimientos obligatorios para CADA vulnerabilidad

7.1 Ficha técnica

- Nombre del hallazgo.
- Tipo: SAST o SCA.
- CVE y/o CWE, si está disponible.
- Severidad reportada.
- CVSS v3.1 y vector, cuando esté disponible.
- Archivo, dependencia y línea/ubicación.
- Versión vulnerable y versión segura, cuando corresponda.

7.2 Interpretación del riesgo

- Vector de ataque y privilegios requeridos, cuando aplique.
- Impacto sobre Confidencialidad, Integridad y Disponibilidad.
- Activo o componente expuesto.
- Condiciones necesarias para aprovecharlo.
- Impacto técnico y empresarial.

ASIGNATURA	CÓDIGO: ING: Diplociber	NOMBRE: Implementación Práctica: Snyk, CLI
PROFESOR: Edwin Andrés Ochoa Agudelo		FECHA: 29/10/2026

TIPO DEVALUACIÓN	TALLER	QUIZ	PARCIAL	FINAL	¿OTRO – CUÁL?
	N°5→10%				

- Evidencia de explotación pública/madurez del exploit, si está disponible.
- Reachability o alcance real del componente, cuando pueda determinarse.

7.3 Causa raíz

- Mostrar fragmento vulnerable antes de corregir.
- Indicar archivo y líneas.
- Explicar defecto de diseño, implementación, configuración o dependencia.
- Relacionar con CWE/OWASP cuando corresponda.

7.4 Escenario de explotación controlada

Describir cómo un adversario podría aprovechar la debilidad y qué daño causaría, sin atacar sistemas externos. Si el laboratorio permite demostración segura, incluir únicamente la evidencia necesaria.

7.5 Remediación

- Explicar estrategia.
- Mostrar código/dependencia ANTES.
- Aplicar corrección.
- Mostrar DESPUÉS.
- Justificar que corrige la causa raíz.
- Comprobar funcionalidad.
- Si es dependencia, documentar actualización, sustitución o mitigación.

7.6 Verificación obligatoria

Reejecutar el análisis: snyk code test para SAST y snyk test para SCA. La evidencia debe demostrar que el hallazgo desapareció o explicar técnicamente por qué permanece y qué mitigación existe.

7.7 Prevención y Shift-Left

- Regla .cursorrules.
- ESLint/Semgrep u otra regla equivalente.
- Hook pre-commit.
- Secret scanning cuando corresponda.
- Quality Gate CI/CD.
- Bloqueo de Pull Request ante severidad crítica.
- Política de actualización y control de dependencias.

ASIGNATURA	CÓDIGO: ING: Diplociber	NOMBRE: Implementación Práctica: Snyk, CLI
PROFESOR: Edwin Andrés Ochoa Agudelo		FECHA: 29/10/2026

TIPO DEVALUACIÓN	TALLER	QUIZ	PARCIAL	FINAL	¿OTRO – CUÁL?
	N°5→10%				

8. Matriz obligatoria de vulnerabilidades

#	Hallazgo	SAST/SCA	CVE/CWE	Seve-ridad	CVSS	Riesgo real	Estado
1	...	SAST	...	...	...	...	Corregi-do
2	...	SCA	...	...	...	...	Corregi-do
3	...	SAST/SCA	...	...	...	...	Corregi-do

9. Evidencia antes / después

Cada vulnerabilidad debe incluir: 1) hallazgo inicial en Snyk, 2) ubicación en código/dependencia, 3) análisis técnico, 4) corrección, 5) diff o evidencia del cambio y 6) nuevo escaneo demostrando el resultado.

10. Integración con Cursor + MCP (cuando sea habilitada)

Registrar qué herramienta MCP fue invocada, qué hallazgo analizó, qué propuesta realizó el agente y qué revisión humana se efectuó. Inspeccionar el diff, verificar la lógica de negocio y volver a ejecutar el análisis. La IA no sustituye el criterio del auditor.

11. Entregable principal

Crear en la raíz del proyecto:

SECURITY_LAB_REPORT.md

- Portada técnica: auditor(es), repositorio, fecha y entorno.
- Resumen ejecutivo.
- Metodología y alcance.
- Matriz de las 3 vulnerabilidades.
- Ficha completa de Vulnerabilidad 1.
- Ficha completa de Vulnerabilidad 2.
- Ficha completa de Vulnerabilidad 3.
- Comparación antes/después.
- Evidencias de reescaneo.
- Controles preventivos y Quality Gate.

ASIGNATURA	CÓDIGO: ING: Diplociber	NOMBRE: Implementación Práctica: Snyk, CLI
PROFESOR: Edwin Andrés Ochoa Agudelo		FECHA: 29/10/2026

TIPO DEVALUACIÓN	TALLER	QUIZ	PARCIAL	FINAL	¿OTRO – CUÁL?
	N°5→10%				

- Conclusiones.
- Anexos con evidencias.

12. Estructura mínima de cada vulnerabilidad

6. Ficha técnica y puntuación.
7. Interpretación de CVSS y riesgo.
8. Causa raíz.
9. Escenario de explotación.
10. Código/dependencia vulnerable (ANTES).
11. Remediación aplicada.
12. Código/dependencia corregida (DESPUÉS).
13. Evidencia del reescaneo.
14. Prevención a futuro y Shift-Left.

13. Rúbrica de evaluación

Criterio	Peso	Qué se evalúa
Identificación y métricas	20%	SAST/SCA, CVE/CWE, CVSS, ubicación y matriz.
Causa raíz y riesgo	20%	Explicación técnica, CIA, vector, contexto y riesgo real.
Calidad de remediación	25%	Corrección funcional y reescaneo satisfactorio.
Evidencia y trazabilidad	15%	Capturas/salidas, antes/después, diff y resultados.
Shift-Left y controles	10%	Regla, pre-commit, SAST/SCA, Quality Gate o CI/CD.
Informe y conclusiones	10%	Orden, lenguaje técnico y conclusiones sustentadas.

14. No se acepta

- Copiar Snyk sin interpretación.

ASIGNATURA	CÓDIGO: ING: Diplociber	NOMBRE: Implementación Práctica: Snyk, CLI
PROFESOR: Edwin Andrés Ochoa Agudelo		FECHA: 29/10/2026

TIPO DEVALUACIÓN	TALLER	QUIZ	PARCIAL	FINAL	¿OTRO – CUÁL?
	N°5→10%				

- Usar solo CVSS como análisis de riesgo.
- Corregir sin demostrar reescaneo.
- Parchear rompiendo funcionalidad.
- Proponer solo 'tener más cuidado'.
- Publicar secretos.
- Probar fuera del entorno autorizado.
- Entregar capturas sin explicación.

15. Preguntas de cierre

15. ¿Cuál de las tres vulnerabilidades representa mayor riesgo real y por qué?
16. ¿La mayor puntuación CVSS siempre debe corregirse primero?
17. ¿Qué diferencia hay entre vulnerabilidad identificada y vulnerabilidad explotable?
18. ¿Qué impacto tiene sobre CID?
19. ¿Qué control habría detectado el problema antes de producción?
20. ¿Cómo llevaría ese control al CI/CD?
21. ¿Qué limitaciones observó en la automatización?
22. ¿Qué parte requiere criterio humano?

16. Cierre académico

La actividad debe demostrar que AppSec no consiste únicamente en ejecutar un escáner. El resultado esperado es un proceso completo: identificar, comprender, priorizar, corregir, verificar y prevenir. El estudiante deberá transformar los hallazgos técnicos de Snyk en decisiones de seguridad sustentadas, con evidencia reproducible y controles que incorporen seguridad desde las primeras etapas del desarrollo.

17. Base documental de la actividad

La actividad toma como base los tres documentos suministrados: la guía inicial de actividad, el material de Auditoría de Seguridad de Aplicaciones y Gestión Continua del Riesgo y la Implementación Práctica de Snyk CLI y MCP en Cursor. Estos materiales establecen SAST/SCA, CVE/CWE/CVSS, priorización contextual, Shift-Left, remed